

Tinker Tailor LLM Spy

Reconstructing 'Deleted' Chats & Hijacking Sessions from Chromium Caches

Dr. Sapna Vikram Mewundi

Lead Forensics Researcher, Verity Project

Black Hat India 2026 Submission Proposal

The Ephemeral AI Fallacy

- **The Illusion:** Users paste code/credentials into LLM portals (ChatGPT/Claude/Gemini) and delete the chats to avoid tracking.
- **The Reality:** Chromium IndexedDB (backed by LevelDB LSM-tree) writes append-only. Deleted rows persist in raw logs (.log) and SSTables (.sst/.ldb).
- **The Risk:** Malware, compromise, or malicious insiders can carve these unencrypted caches to steal high-value corporate IP.

Chromium LevelDB Forensics

- **Target Paths:** Located in Local AppData folders under browser profiles (Default, Profile 1, Profile 3, etc.).
- **LSM-Tree Blocks:** Multi-level Sorted String Tables (SSTables) compressed with Snappy.
- **Exclusive Locks:** Browsers place exclusive file locks (LOCK) on active databases.
- **Triage Constraint:** Traditional tools require C++ leveldb compiling (plyvel), which is prohibited on production endpoint environments.

Reversing V8 ValueSerializer

- **IndexedDB Schema:** Records are serialized using V8's internal binary format.
- **Varint32 Reader:** Numbers are serialized using Protocol Buffer-style base-128 varints.
- **OneByteString (0x22):** Standard ASCII string containing length prefix and bytes.
- **TwoByteString (0x63):** UTF-16LE string. Length represents byte count, not character count. Reading too far causes parser alignment drift.

Decoding Conversation Trees

- **Smi-Shifted Keys:** Indexes in V8 arrays are shifted left by 1 bit (actual = encoded $\gg 1$).
- **Role Parity Math:** Distinguish user vs assistant using actual index parity:
role = 'user' if $(\text{index} / 2) \bmod 2 = 1$ else 'assistant'
- **Nesting Depth Tracking:** Incrementing depth on object/array start (0x6f, 0x61), decrementing on end (0x7b). Prevents early termination on sub-properties.
- **Chronology:** Ordering using file modification times (mtime) and database byte offsets.

Scenario 1: Insider Data Exfiltration

- **The Incident:** A developer uploads sensitive source code and API keys, then deletes the conversation to cover tracks.
- **The Obstacle:** Active browser maintains exclusive database locks.
- **The Solution:** Open logs in read-only binary mode to bypass locks, clone active records in memory, and parse logs.
- **The Evidence:** Carver successfully reconstructs the complete thread and leaked code block.

Scenario 2: AI Account Hijacking

- **The Incident:** Infostealer malware harvests browser IndexedDB directories from target endpoints.
- **The Vulnerability:** Active OAuth session tokens and JWTs for AI portals are stored in plaintext inside IndexedDB (bypassing DPAPI/Keychain).
- **The Takeover:** Attacker extracts the cookie string and takes over the user's active session without requiring credentials or triggering MFA.

Verity: Pure-Python Forensic Tool

- **Zero Dependencies:** Single-file python script running without compiled binary modules.
- **Dynamic sweeps:** Automatically walks and detects all default and custom Chrome/Edge browser user profiles.
- **Forensic Integrity:** Seals outputs with HMAC-SHA256 signatures, verified in-browser using Web Cryptography API to guarantee chain of custody.
- **Timeline Explorer:** A clean web-based dashboard interface to review evidence.

Enterprise Mitigations

- **Purge Policies:** Configure enterprise browsers to evict and wipe IndexedDB directories on user session logout.
- **Disk Protection:** Enforce full-disk encryption (BitLocker, FileVault) to prevent offline physical disk carving.
- **EDR Monitoring:** Create threat rules to flag unusual read/copy requests on browser AppData folders.

Conclusion

- **Summary:** Ephemeral GenAI sessions leave deep, recoverable traces locally.
- **GitHub Release:** Open-source code available at: github.com/prajwalchowdary2/verity-forensics
- **Whitepaper:** Comprehensive academic whitepaper submitted to Review Board.

Q&A; — Thank You!